📝 BUS 4101: E-Commerce Class Test (Payments, Security & Law)

Focus: Classes 07–09 | JUST Dept. of CSE

1. Class 07: Payment Systems

The Card Ecosystem (Roles)

- **Issuing Bank:** The cardholder's bank (e.g., DBBL, BRAC). Authorizes/declines transactions.
- **Acquiring Bank:** The merchant's bank (e.g., EBL). Maintains the merchant account.
- **Payment Gateway:** The tech bridge (e.g., **SSL Commerz**). Encrypts and transmits data.
- **Card Network:** The "rails" (Visa, Mastercard). Routes messages between banks.

Key Concepts

- **Authorization:** Real-time check for funds. **Does not move money**; only reserves it.
- **Settlement:** The actual transfer of funds (usually $T + 1$ to $T + 3$ days).
- **Tokenization:** Replacing the 16-digit card number (PAN) with a random "token" to prevent data theft.
- **MFS (Mobile Financial Services): bKash** and **Nagad**. Essential for the unbanked in BD.

2. Class 08: Encryption & Security Protocols

The 5 Dimensions of Security

1. **Confidentiality:** Only authorized people can read (Threat: Interception).
2. **Integrity:** Data hasn't been changed (Threat: Tampering).
3. **Availability:** System is up (Threat: DDoS).
4. **Authenticity:** Identity is genuine (Threat: Phishing).
5. **Non-repudiation:** Cannot deny a transaction (Threat: Order dispute).

Encryption & Hashing

- **Symmetric (AES):** One key for both. Fast, used for bulk data.
- **Asymmetric (RSA):** Two keys (Public/Private). Used for key exchange and signatures.
  - **RSA Formula (High Probability):** $C = M^e \pmod{n}$ (Encryption).
- **Hash Function (SHA-256):** One-way, fixed-size digest. Used for passwords and integrity.

- **Digital Signatures:** Rule: **Sign with Private Key, Verify with Public Key.**

SSL/TLS Handshake

- **Purpose:** Authenticate the server and establish a secret symmetric **session key**.
- **CA (Certificate Authority):** Trusted third party (e.g., Let's Encrypt) that issues digital certificates.

3. Class 09: Threats, Ethics & Legal Issues

Technical Threats

- **SQL Injection (SQLi):** Malicious SQL in input fields. Prevention: **Parameterized queries**.
- **XSS (Cross-Site Scripting):** Injecting JS into pages. Goal: Steal session cookies.
- **CSRF:** Tricking a logged-in user's browser into performing actions. Prevention: **CSRF Tokens**.
- **Social Engineering:** Phishing (generic), Spear Phishing (targeted), Vishing (voice), Smishing (SMS).

Ethics & Dark Patterns

- **Dark Patterns:** UI tricks (e.g., "Confirmshaming," hidden costs/drip pricing, "Roach motels" for hard cancellation).
- **Price Discrimination:** Charging different prices based on willingness to pay (e.g., iOS vs. Android users).

Privacy & Law

- **GDPR (EU):** Opt-in consent, Right to be Forgotten, 72-hour breach notice. (Fines: 4% of global revenue).
- **Digital Security Act (DSA) 2018 (BD):**
  - **Section 17:** Attacking Critical Infrastructure (14 years).
  - **Section 19:** Unauthorized Access/Hacking (7 years).
- **ICT Act 2006 (BD):** Gives **legal validity** to electronic documents and digital signatures.

💡 Quick Exam Checklist

- **RSA Rule:** What one key encrypts, *only* the other key can decrypt.
- **Hashing Rule:** You cannot reverse a hash to find the original password.